

Credential Access

(TA0006)

청주대학교 디지털보안학과 시스템보안실습

Credential Access

- The adversary is **trying to steal account names and passwords**.

Credential Access

- Credential Access consists of techniques for stealing credentials like account names and passwords.
- Techniques used to get credentials **include keylogging or credential dumping**.
- Using legitimate credentials can give adversaries access to systems, make them harder to detect, and provide the opportunity to create more accounts to help achieve their goals.

Credential? (네이버 IT용어사전)

- 정보 시스템의 특정 응용에서 사용하는 암호학적 개인 정보(**personal information**).
- 이용자가 허용된 사람인지를 검증하기 위해 사용하는 암호학적 정보인 패스워드, 공개 키 암호 알고리즘에서 사용하는 공개 키/개인 키 쌍, 전자서명인증사업자가 발행하는 공개 키 인증서(**certificate**), 신뢰하는 루트 인증기관(예, **KISA** 최상위 인증기관) 관련 정보, 인가 정보 등이 포함될 수 있음

Credential? (네이버 IT용어사전)

- 데스크톱 컴퓨터, 노트북 컴퓨터, 개인 휴대 정보 단말기 (PDA), 휴대폰 등 특정 디바이스의 특정 응용에서 사용하던 크리덴셜을 다른 디바이스로 이동하려는 요구가 점점 증가하면서 미국 RSA사에서 제정한 사실 표준인 PKCS (Public-Key Cryptography Standard) 표준에 기초하여 IETF (internet task force engineering) 보안 영역의 SACRED (Securely Available CREdentials) 작업반에서 크리덴셜 이동성 지원 기술의 표준화를 진행하고 있음

Credential? [보안뉴스]

- 크리덴셜(Credential)의 사전적 의미는 '자격증명'
- 일반적으로는 특정인이 해당 자격을 가지고 있는지를 증명하는 수단을 의미
 - 각종 신분증과 증명서 등이 바로 Credential에 해당
- 출입보안에서 '자격증명'이란 출입할 수 있는 자격과 그 자격을 증명하는 구체적인 것
- 자격을 증명하는 구체적인 수단이란 바로 출입하고 바로 문을 열 수 있는 수단을 의미
- 출입보안에서의 Credential 즉, 문을 열 수 있는 수단은 열쇠와 비밀번호, RF카드, 생체정보, 스마트폰에 이르기까지 다양하다.

Techniques

- Adversary-in-the-Middle
- Brute Force
- Credentials from Password Stores
- Exploitation for Credential Access
- Forced Authentication
- Forge Web Credentials
- Input Capture
- Modify Authentication Process
- Multi-Factor Authentication Interception
- Multi-Factor Authentication Request Generation

Techniques

- Network Sniffing
- OS Credential Dumping
- Steal Application Access Token
- Steal or Forge Authentication Certificates
- Steal or Forge Kerberos Tickets
- Steal Web Session Cookie
- Unsecured Credentials

Brute Force

- Adversaries may use brute force techniques to gain access to accounts when passwords are unknown or when password hashes are obtained.
- Without knowledge of the password for an account or set of accounts, an adversary may systematically guess the password using a repetitive or iterative mechanism.
- Brute forcing passwords can take place via interaction with a service that will check the validity of those credentials or offline against previously acquired credential data, such as password hashes.

Brute Force

- Brute forcing credentials may take place at various points during a breach.
 - For example, adversaries may attempt to brute force access to Valid Accounts within a victim environment leveraging knowledge gathered from other post-compromise behaviors such as OS Credential Dumping, Account Discovery, or Password Policy Discovery.
- Adversaries may also combine brute forcing activity with behaviors such as External Remote Services as part of Initial Access.

Brute Force: Sub-techniques

- Password Guessing
- Password Cracking
- Password Spraying
- Credential Stuffing

Brute Force: Password Cracking

- Adversaries may use password cracking to attempt to recover usable credentials, such as plaintext passwords, when credential material such as password hashes are obtained.
- OS Credential Dumping can be used to obtain password hashes, this may only get an adversary so far when Pass the Hash is not an option.
- Further, adversaries may leverage Data from Configuration Repository in order to obtain hashed credentials for network devices.

Brute Force: Password Cracking

- Techniques to systematically guess the passwords used to compute hashes are available, or the adversary may use a pre-computed rainbow table to crack hashes.
- Cracking hashes is usually done on adversary-controlled systems outside of the target network.
- The resulting plaintext password resulting from a successfully cracked hash may be used to log into systems, resources, and services in which the account has access.

Brute Force: Password Guessing

- Adversaries with no prior knowledge of legitimate credentials within the system or environment may *guess passwords to attempt access to accounts*.
- Without knowledge of the password for an account, an adversary may opt to systematically guess the password using a repetitive or iterative mechanism.
- An adversary may guess login credentials without prior knowledge of system or environment passwords *during an operation* by *using a list of common passwords*.
- Password guessing may or may not take into account the target's policies on password complexity or use policies that may lock accounts out after a number of failed attempts.

Brute Force: Password Guessing

- Guessing passwords can be a *risky option* because it could **cause numerous authentication failures and account lockouts**, depending on the organization's login failure policies.

Brute Force: Password Guessing

- Typically, management services over commonly used ports are used when guessing passwords.
- Commonly targeted services include the following:
 - SSH (22/TCP)
 - Telnet (23/TCP)
 - FTP (21/TCP)
 - NetBIOS / SMB / Samba (139/TCP & 445/TCP)
 - LDAP (389/TCP)
 - Kerberos (88/TCP)
 - RDP / Terminal Services (3389/TCP)
 - HTTP/HTTP Management Services (80/TCP & 443/TCP)

Brute Force: Password Guessing

- MSSQL (1433/TCP)
- Oracle (1521/TCP)
- MySQL (3306/TCP)
- VNC (5900/TCP)
- SNMP (161/UDP and 162/TCP/UDP)

Brute Force: Password Guessing

- In addition to management services, adversaries may “target single sign-on (SSO) and cloud-based applications utilizing federated authentication protocols,” as well as externally facing email applications, such as Office 365.
- Further, adversaries may abuse network device interfaces (such as wlanAPI) to brute force accessible wifi-router(s) via wireless authentication protocols.
- In default environments, LDAP and Kerberos connection attempts are less likely to trigger events over SMB, which creates Windows “logon failure” event ID 4625.

Brute Force: Password Spraying

- Adversaries may use a single or small list of commonly used passwords against many different accounts to attempt to acquire valid account credentials.
- Password spraying uses one password (e.g. 'Password01'), or a small list of commonly used passwords, that may match the complexity policy of the domain.
- Logins are attempted with that password against many different accounts on a network to avoid account lockouts that would normally occur when brute forcing a single account with many passwords.

Brute Force: Credential Stuffing

- Adversaries may use credentials obtained from breach dumps of unrelated accounts to gain access to target accounts through credential overlap.
- Occasionally, large numbers of username and password pairs are dumped online when a website or service is compromised and the user account credentials accessed.
- The information may be useful to an adversary attempting to compromise accounts by taking advantage of the tendency for users to use the same passwords across personal and business accounts.

Brute Force: Credential Stuffing

- Credential stuffing is a risky option because it could **cause numerous authentication failures and account lockouts**, depending on the organization's login failure policies.